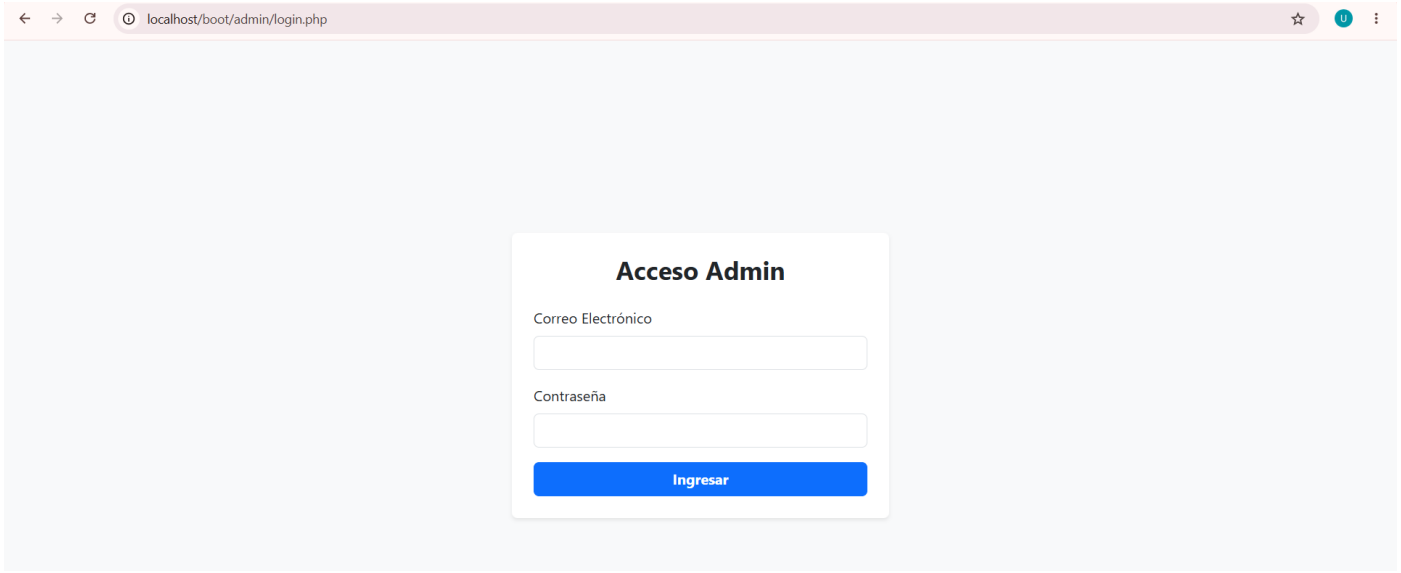
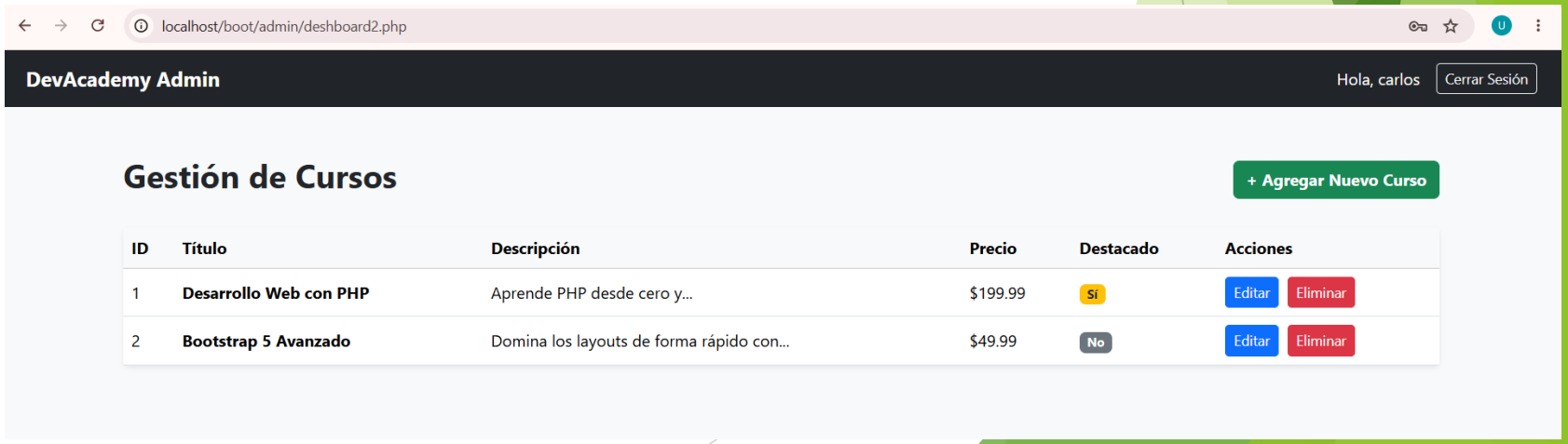
Login

Carlos Andrés Rodríguez Argüelles

Requisitos login y Dashboard





Inicio de Sesión y Conexión

```
<?php
session_start();
require_once __DIR__ .
'/../config/conexion.php';
?>
```

- session_start(): Es obligatoria en la primera línea. Le avisa al servidor que vamos a usar la memoria temporal (sesiones) para recordar quién ha entrado.
- require_once: Trae nuestro archivo centralizado de conexión a la base de datos para poder hacer consultas.

El "Atajo" de Seguridad (¿Ya estás logueado?)

```
if (isset($_SESSION['admin_id'])) {
    header('Location: deshboard2.php');
    exit;
}
```

- Evaluamos si la variable de sesión $_SESSION['admin_id'] ya existe.Si el administrador ya ingresó sus datos previamente, no tiene sentido mostrarle el formulario de login de nuevo.
- Lo redirigimos automáticamente al panel (deshboard2.php) usando header() y cerramos el script con exit.

Manejo de Errores y Seguridad por URL ($_GET)

```
$error = '';

if (isset($_GET['error']) && $_GET['error'] === 'acceso_denegado') {

    $error = 'Debes iniciar sesión para poder acceder al panel de administración.';

}
```

- Si alguien intenta entrar al dashboard escribiendo la URL directamente sin loguearse, el dashboard los rebota de vuelta aquí con un parámetro en la URL (?error=acceso_denegado).
- Con $_GET['error'] capturamos ese aviso y personalizamos la variable $error para mostrarle una alerta roja al usuario.

Manejo de Errores y Seguridad por URL ($_GET)

```
<?php
session_start();


// 1. CANDADO DE SEGURIDAD: Si no ha iniciado sesión, fuera de aquí
if (!isset($_SESSION['admin_id'])) {
    header('Location: login.php?error=acceso_denegado');
    exit;
}
```

- Este código ira en el dashboard.php

```php
<?php
session_start();
// Carga la conexión
require_once __DIR__ . '/../config/conexion.php';

// Si ya hay sesión activa, entra directo al dashboard, se crea la variable de session llamada admin
if (isset($_SESSION['admin_id'])) {
    header('Location:deshboard2.php');
    exit;
}
$error = '';
// <-- Capturas el mensaje y mandas el error -->
if (isset($_GET['error']) && $_GET['error'] === 'acceso_denegado') {
    $error = 'Debes iniciar sesión para poder acceder al panel de administración.';
}
```

Seguridad contra Inyección SQL (Consultas Preparadas)

```
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $email = trim($_POST['email'] ?? '');
    $password = trim($_POST['password'] ?? '');

    $sql = "SELECT id, nombre, email, psw FROM usuarios WHERE email = ? AND rol = 'admin'";
    $stmt = mysqli_prepare($conexion, $sql);
    mysqli_stmt_bind_param($stmt, "s", $email);
    mysqli_stmt_execute($stmt);
    $resultado = mysqli_stmt_get_result($stmt);
    $usuario = mysqli_fetch_assoc($resultado);
}
```

- Validamos que el método sea POST y limpiamos los espacios con trim().
- Los signos de interrogación (?) en la consulta SQL. En lugar de concatenar variables directamente (lo cual sería vulnerable a ataques de inyección SQL), usamos mysqli_prepare y mysqli_stmt_bind_param para inyectar el correo de forma totalmente segura.
- Filtrar estrictamente por rol = 'admin' para asegurarnos de que un usuario común no pueda entrar aunque adivine su contraseña.

Autenticación Exitosa y Creación de Credenciales de Sesión

```
if ($usuario && $password === $usuario['psw']) {
    $_SESSION['admin_id'] = $usuario['id'];
    $_SESSION['admin_nombre'] = $usuario['nombre'];
    $_SESSION['rol'] = 'admin';
    header('Location:deshboard2.php');
    exit;
} else {
    $error = 'Credenciales incorrectas o no tienes permisos de administrador.';
}
```

- Compar la contraseña ingresada con la almacenada en la base de datos ($usuario['psw']).
- Si coinciden, el servidor "firma" la entrada creando las variables de sesión ($_SESSION['admin_id'], $_SESSION['admin_nombre'], $_SESSION['rol']).
- Estas variables viajarán con el usuario por todo el sitio web.
- Finalmente, panel con header('Location: deshboard2.php'). Si fallan, se muestra el mensaje genérico de error por seguridad.

```php
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $email = trim($_POST['email'] ?? '');
    $password = trim($_POST['password'] ?? '');
    if (!empty($email) && !empty($password)) {
        // Consulta SQL limpia filtrando por rol admin
        $sql = "SELECT id, nombre, email, psw FROM usuarios WHERE email = ? AND rol = 'admin'";
        $stmt = mysqli_prepare($conexion, $sql);
        if ($stmt) {
            mysqli_stmt_bind_param($stmt, "s", $email);
            mysqli_stmt_execute($stmt);
            $resultado = mysqli_stmt_get_result($stmt);
            $usuario = mysqli_fetch_assoc($resultado);
            if ($usuario && $password === $usuario['psw']) {
                $_SESSION['admin_id'] = $usuario['id'];
                $_SESSION['admin_nombre'] = $usuario['nombre'];
                $_SESSION['rol'] = 'admin';
                header('Location:deshboard2.php');
                exit;
            } else {
                $error = 'Credenciales incorrectas o no tienes permisos de administrador.';
            }
            mysqli_stmt_close($stmt);
        } else {
            $error = 'Error en la consulta a la base de datos: ' . mysqli_error($conexion);
        }
    } else {
        $error = 'Por favor llena todos los campos.';
    }
}
?>
```

Renderizado de Errores con Bootstrap y XSS Protection

```
<?php if ($error): ?>
    <div class="alert alert-danger py-2"><?= htmlspecialchars($error) ?></div>
<?php endif; ?>
```

- Mostramos cómo el código PHP se mezcla con el HTML de Bootstrap (alert alert-danger).
- El uso de htmlspecialchars($error): es buena práctica obligatoria para evitar ataques de tipo XSS (Cross-Site Scripting), asegurando que cualquier mensaje impreso en pantalla se interprete como texto plano y no como código malicioso.

```php
<body class="bg-light d-flex align-items-center min-vh-100">
    <div class="container">
        <div class="row justify-content-center">
            <div class="col-md-4">
                <div class="card shadow-sm border-0">
                    <div class="card-body p-4">
                        <h3 class="card-title text-center fw-bold mb-4">Acceso Admin</h3>

                        <?php if ($error): ?>
                            <div class="alert alert-danger py-2"><?= htmlspecialchars($error) ?></div>
                        <?php endif; ?>

                        <form method="POST" action="">
                            <div class="mb-3">
                                <label for="email" class="form-label">Correo Electrónico</label>
                                <input type="email" name="email" id="email" class="form-control" required>
                            </div>
                            <div class="mb-3">
                                <label for="password" class="form-label">Contraseña</label>
                                <input type="password" name="password" id="password" class="form-control" required>
                            </div>
                            <button type="submit" class="btn btn-primary w-100 fw-bold">Ingresar</button>
                        </form>
                    </div>
                </div>
            </div>
        </div>
    </div>
</body>
```

Dashboard.php (sesión)

```php
<?php
session_start();

// 1. CANDADO DE SEGURIDAD: Si no ha iniciado sesión, fuera de aquí
if (!isset($_SESSION['admin_id'])) {
    header('Location: login.php?error=acceso_denegado');
    exit;
}
?>
```

Dashboard.php (body-header)

```php
<body class="bg-light">
    <!-- Encabezado de navegación de la aplicación -->
    <header>
        <nav class="navbar navbar-expand-lg navbar-dark bg-dark px-4">
            <a class="navbar-brand fw-bold" href="#">DevAcademy Admin</a>
            <div class="ms-auto text-white d-flex align-items-center">
                <!-- Nombre del administrador dinámico desde la sesión -->
                <span class="me-3">Hola, <?= htmlspecialchars($_SESSION['admin_nombre'] ?? 'Administrador') ?></span>
                <a href="logout.php" class="btn btn-outline-light btn-sm">Cerrar Sesión</a>
            </div>
        </nav>
    </header>
```

Dashboard.php (tabla-Encabezado)

```
<!-- Contenido principal de la página -->
<main class="container py-5">
    <!-- Sección del título y acción principal -->
    <div class="d-flex justify-content-between align-items-center mb-4">
        <h1 class="h2 fw-bold">Gestión de Cursos</h1>
        <a href="curso_crear.php" class="btn btn-success fw-bold">+ Agregar Nuevo Curso</a>
    </div>
    <!-- Contenedor de la tabla informativa -->
    <section class="card shadow-sm border-0">
        <div class="card-body p-0">
            <table class="table table-hover align-middle mb-0">
                <thead class="table-light">
                    <tr>
                        <th>ID</th>
                        <th>Título</th>
                        <th>Descripción</th>
                        <th>Precio</th>
                        <th>Destacado</th>
                        <th>Acciones</th>
                    </tr>
                </thead>
```

Dashboard.php (tabla-Cuerpo Tabla)

```
<tbody>
    <!-- Fila de ejemplo 1 -->
    <tr>
        <td>1</td>
        <td class="fw-bold">Desarrollo Web con PHP</td>
        <td>Aprende PHP desde cero y...</td>
        <td>$199.99</td>
        <td>
            <span class="badge bg-warning text-dark">Sí</span>
        </td>
        <td>
            <a href="curso_editar.php?id=1" class="btn btn-primary btn-sm me-1">Editar</a>
            <a href="curso_eliminar.php?id=1" class="btn btn-danger btn-sm">Eliminar</a>
        </td>
    </tr>
    <!-- Fila de ejemplo 2 -->
    <tr>
        <td>2</td>
        <td class="fw-bold">Bootstrap 5 Avanzado</td>
        <td>Domina los layouts de forma rápido con...</td>
        <td>$49.99</td>
        <td>
            <span class="badge bg-secondary">No</span>
        </td>
        <td>
            <a href="curso_editar.php?id=2" class="btn btn-primary btn-sm me-1">Editar</a>
            <a href="curso_eliminar.php?id=2" class="btn btn-danger btn-sm">Eliminar</a>
        </td>
    </tr>
</tbody>
</table>
```

Son datos Estáticos, falta hacerlo con BD

Dashboard.php (cierra body)

```
                </table>
            </div>
        </section>
    </main>
</body>
</html>
```